



The OWASP Identity & NHI Companion

A field guide for IAM practitioners.

The OWASP resources you can actually use, condensed to fit in your bag. Non-Human Identities Top 10, Top 10 for Agentic Applications, ASVS 5.0, and the Cheat Sheet Series, all in one place.

Welcome

You picked this up at the OWASP New York table at the NY IAM Summit. This booklet is a compressed field guide to OWASP's identity, non-human identity, and agentic AI resources, designed to fit in your bag and stay useful after the conference.

ABOUT OWASP

OWASP is a community-led non-profit that works to improve the security of software through open-source, peer-reviewed projects. Its resources are free, used worldwide, and produced by tens of thousands of volunteer contributors. OWASP is vendor-neutral and does not endorse commercial products.

ABOUT OWASP NEW YORK CITY

The OWASP New York City Chapter is free to join and open to all. We meet to discuss & demonstrate vulnerabilities, tools & solutions across application, API, identity, and AI security. The chapter meets monthly and is co-led by Guy Osa, Zoe Braiterman, Carlos Mena, and Fernando Burgos.

HOW TO PLUG IN

- **Meetup:** [meetup.com/owasp-new-york-city-chapter](https://www.meetup.com/owasp-new-york-city-chapter)
- **Chapter page:** owasp.org/www-chapter-new-york-city/
- **LinkedIn:** [linkedin.com/company/owasp-nyc](https://www.linkedin.com/company/owasp-nyc)

Chapter meetings are free and open to all.

You do not need to be an OWASP member to attend, but joining supports the community and its projects. Learn more at owasp.org/membership.

OWASP for identity practitioners

Six OWASP projects touch identity directly. Use this page as your index. Every resource on this list is free, peer-reviewed, and community-maintained.

OWASP Top 10

A01 Broken Access Control · A07 Identification and Authentication Failures. The industry-standard web app risk list.

owasp.org/Top10

OWASP API Security Top 10 (2023)

API1 BOLA (~40% of API attacks) · API2 Broken Authentication. Essential for API teams.

owasp.org/API-Security

OWASP ASVS 5.0

May 2025. 350 requirements across 17 chapters. V6 Authentication, V7 Session Management, V8 Authorization.

owasp.org/www-project-application-security-verification-standard

OWASP Cheat Sheet Series

Authentication, Authorization, OAuth 2.0, OIDC, SAML, JWT, Session Management. Copy-ready guidance.

cheatsheetseries.owasp.org

OWASP Non-Human Identities Top 10 (2025)

10 risks for service accounts, workload identity, and machine identity. See pages 4 and 5.

owasp.org/www-project-non-human-identities-top-10

OWASP Top 10 for Agentic Applications (2026)

Peer-reviewed risks for autonomous AI agents. Published Dec 9, 2025. See page 6.

genai.owasp.org

Non-Human Identities Top 10 (2025)

Published in 2025 by OWASP, ranked using the OWASP Risk Rating Methodology from real-world breaches, CVE data, surveys, and practitioner feedback. Non-human identities include service accounts, API keys, OAuth tokens, workload identities, and agent identities, the population growing faster than governance can catch up.

NHI1:2025 Improper Offboarding

Non-human identities that outlive the workload, service, or contract that needed them. Old service accounts and unrotated API keys remain valid credentials to attackers.

NHI2:2025 Secret Leakage

Credentials committed to source control, embedded in container images, or exposed in logs. The single most common way NHI credentials fall into attacker hands.

NHI3:2025 Vulnerable Third-Party NHI

SaaS integrations, OAuth apps, and marketplace add-ons that hold broad access to your environment. When they break, they take you with them.

NHI4:2025 Insecure Authentication

Long-lived shared secrets, no rotation, no sender-constraint (DPoP or mTLS), no proof-of-possession. Human-designed auth patterns applied to workloads that need better.

NHI5:2025 Overprivileged NHI

Service accounts and workload identities granted more permission than the workload needs, often because permissions grow with time but never shrink.

NHI Top 10, continued

Items 6 through 10

NHI6:2025 Insecure Cloud Deployment Configurations

Misconfigured IAM roles, public S3 buckets tied to service accounts, and cloud identities with implicit trust that was never intended. The default that stayed the default.

NHI7:2025 Long-Lived Secrets

API keys and tokens that never rotate, or rotate on a cadence measured in years. Rotation as a paper policy is not rotation.

NHI8:2025 Environment Isolation

Non-human identities that cross environment boundaries (dev, staging, prod) and expand blast radius. One compromised dev token, one production incident.

NHI9:2025 NHI Reuse

One identity used by many services, one credential used by many identities. Reuse is the enemy of blast-radius containment.

NHI10:2025 Human Use of NHI

Humans logging in with service account credentials, sharing NHI secrets in chat, or using workload identities for interactive access. Governance collapses at the point of reuse.

Full list, methodology, and detailed guidance:

owasp.org/www-project-non-human-identities-top-10

Take the 20-question NHI self-audit on the next two pages.

NHI Self-Audit

Twenty yes/no questions, two per NHI Top 10 risk. Tick every box where your answer is YES. Score on page 8. Bring the completed audit back to your team on Monday.

- ☐ **NHI1** Do you have a documented process for revoking every credential associated with a service when it is decommissioned?
- ☐ **NHI1** Are dormant service accounts (no activity for 30, 60, or 90 days) automatically flagged for review or removal?
- ☐ **NHI2** Do you run pre-commit or CI/CD secret scanning across every repository in your organization?
- ☐ **NHI2** Do you keep secrets out of environment variables committed to source, container images, and application logs?
- ☐ **NHI3** Do you maintain an inventory of every third-party SaaS, OAuth app, and marketplace integration with access to your environment?
- ☐ **NHI3** Do you review permissions granted to third-party integrations at least annually?
- ☐ **NHI4** Do a meaningful percentage of your NHIs authenticate with sender-constrained tokens (DPoP, mTLS) rather than long-lived shared secrets?
- ☐ **NHI4** Do you enforce proof-of-possession on high-value machine-to-machine flows?
- ☐ **NHI5** Do you review NHI permissions at least quarterly to catch permission creep?
- ☐ **NHI5** Do service accounts start with least-privilege by default rather than broad roles you narrow later?

NHI Self-Audit, continued

Questions 11 through 20

- ☐ **NHI6** Do you audit your cloud IAM role trust policies on a regular cadence?
- ☐ **NHI6** Do your identity-based policies use conditions (source IP, VPC endpoint, MFA) rather than wildcards on resources?
- ☐ **NHI7** Do all your API keys and machine credentials have a documented rotation cadence measured in days or weeks, not years?
- ☐ **NHI7** Is rotation automated end-to-end, or does it depend on humans remembering to do it?
- ☐ **NHI8** Are production non-human credentials cryptographically separate from staging and development credentials?
- ☐ **NHI8** Do you require additional controls (MFA, network isolation, break-glass) before a developer workstation can reach production NHI credentials?
- ☐ **NHI9** Does each workload have its own distinct identity, without sharing service accounts across workloads?
- ☐ **NHI9** Do you avoid reusing a single API key across multiple services, customers, or integrations?
- ☐ **NHI10** Do you prevent humans from using service account credentials interactively (no chat sharing, no one-off scripts, no console logins)?
- ☐ **NHI10** Do you have detective controls that flag when a human uses a workload identity?

Count your YES ticks. Score interpretation on the next page >

Your NHI posture

Count one point for every YES ticked across the 20 questions. Locate your score below.

18-20**Strong NHI posture**

You are in the top decile. Focus on maintaining the discipline you already have, and expand into agentic risks.

14-17**Reasonable posture with known gaps**

Your foundation is solid, but every zero-answer is a live gap. Fix them before the next audit cycle.

10-13**Significant gaps**

Expect NHI-related incidents in the next 6-12 months unless the zero-answers are addressed as a priority.

0-9**Material business risk**

Escalate to security leadership. NHI posture at this level meaningfully increases breach probability.

WHERE TO START MONDAY MORNING

Look at every question you answered NO. Each one is a live gap. Two shortcuts: if Q7-Q8 both scored NO, your authentication ceiling limits every other control. If Q13-Q14 both scored NO, secret rotation and detection are the Q1 investment that pays for itself.

Top 10 for Agentic Applications (2026)

The first peer-reviewed taxonomy of security risks for autonomous AI agents, published December 9, 2025 by the OWASP GenAI Security Project. Developed with more than 100 industry experts.

Key insight from the framework:

"Agents mostly amplify existing vulnerabilities, not creating entirely new ones."

ASI01 Agent Goal Hijack

Adversaries redirect the agent's plan or objective.

ASI02 Tool Misuse & Exploitation

The agent invokes tools in ways they were not authorized for.

ASI03 Identity & Privilege Abuse

The agent's identity or permissions are misused or escalated.

ASI04 Agentic Supply Chain Vulnerabilities

Third-party tools, frameworks, and agent components carry exposure.

ASI05 Unexpected Code Execution

The agent or sandbox boundary fails and arbitrary code runs.

ASI06 Memory & Context Poisoning

Persistent memory, retrieval, or context is shaped to mislead future steps.

ASI07 Insecure Inter-Agent Communication

Messages between agents are spoofed, replayed, or unauthenticated.

ASI08 Cascading Failures

An error or compromise in one agent fans out across the system.

ASI09 Human-Agent Trust Exploitation

Humans over-trust or are deceived by agent outputs into harmful actions.

ASI10 Rogue Agents

Agents operating outside sanctioned boundaries or acting autonomously without authorization.

Agentic AI quick audit

Eight questions that test whether the identity work behind your AI agents is real. Every agent is a non-human identity, so this audit builds on the NHI Top 10 rather than replacing it. Tick every YES.

- ☐ **ASI03** Does every agent in production have its own distinct identity, separate from the human operator or shared service account?
- ☐ **ASI03** Are agent tokens ephemeral (minutes to hours), rather than persistent for days or longer?
- ☐ **ASI07** Does agent-to-agent communication carry an authenticated identity, or is trust implicit from network position?
- ☐ **ASI02** When an agent invokes a tool, does the authorization decision consider both the agent identity and the delegating user?
- ☐ **ASI09** Do you log every agent action with an identifier that traces back to a specific agent instance and a specific human request?
- ☐ **ASI02** Are agent permissions bound to the specific action requested (RAR), rather than broad-scope tokens the agent narrows at runtime?
- ☐ **ASI10** Do you have controls to detect and quarantine agents operating outside sanctioned tools or scopes?
- ☐ **ASI03** When agents call external services, do those services authenticate the agent as a distinct client, rather than treating it as human traffic?

Why 8 and not 20?

Agents inherit most of the NHI audit. If you scored strong on NHI, take these eight and you have a working read on your agentic identity posture.

Plug in with OWASP New York

The chapter meets monthly, hosts guest speakers, runs secure code events, and partners with the NY Cybersecurity Summit and the Global AppSec conferences.

WHERE TO FIND US

- **Meetup:** meetup.com/owasp-new-york-city-chapter
- **Luma calendar:** luma.com/owasp-new-york-city
- **Chapter page:** owasp.org/www-chapter-new-york-city/
- **LinkedIn:** linkedin.com/company/owasp-nyc
- **Chapter leaders:** Guy Osa · Zoe Braiterman · Carlos Mena · Fernando Burgos

HOW TO CONTRIBUTE TO OWASP

- **Join:** owasp.org/membership (individual and corporate)
- **Contribute:** github.com/OWASP · every project welcomes PRs
- **Attend:** Chapter meetups are free, no membership required

About OWASP NYC

We are always looking for speakers, contributors, and members. If you want to give a talk at a future meetup, please reach out. If you have more questions about Identity and NHI, please reach out to anyone on the OWASP NY Team.

Colophon *(essentially, this booklet's token claims)*

Produced by the OWASP New York City Chapter for the New York IAM Summit 2026. This booklet condenses public OWASP resources and is distributed free at the chapter table.

LICENSE

This booklet is licensed under Creative Commons Attribution-ShareAlike v4.0 (CC BY-SA 4.0), consistent with OWASP's default content license. You may share and adapt this material with attribution.

VENDOR NEUTRALITY

OWASP does not endorse or recommend commercial products or services. The OWASP community remains vendor-neutral. All references to specifications, protocols, and frameworks in this booklet are open standards or OWASP-authored projects.

ACKNOWLEDGMENT

Printing of this booklet for the NY IAM Summit was supported by Curity (curity.io). Curity's contribution is a donation to the chapter, not an endorsement, and does not affect the content, resources, or opinions presented above.